INFORME DE AUDITORÍA FORENSE Y RESPUESTA A INCIDENTES (SOC NIVEL 2)

Análisis Multi-Incidente asistido por IA Generativa, Correlación Heurística y Mapeo MITRE ATT&CK

Dataset Auditado: SOC_L2_Logs_Ampliados_Multiples_Incidentes.xlsx (Hoja: SIEM Export) | **Ventana de Logs:** 2026-10-23 07:46:07 a 2026-10-23 13:44:06
Fecha de Emisión: 2026-11-09 21:51 UTC-5 | **Estado de Contención:** CRÍTICO — 6 Incidentes de Riesgo Alto + 1 Observación de Visibilidad SIEM

715	112	124	12	6 ALTOS + 1 OBS	241.57 MiB
Eventos SIEM Analizados	Alertas Nativas SIEM (No-Info)	Eventos Maliciosos Correlacionados	Eventos Críticos Ocultos en 'Info'	Incidentes Reales Detectados	Exfiltración HTTPS (253.31 MB)

SECCIÓN 1 — RESUMEN EJECUTIVO (ENFOQUE DIRECTIVO Y DE NEGOCIO)

1. RESUMEN GERENCIAL DE LA SITUACIÓN

Durante la ventana operativa del 23 de octubre de 2026 (07:46:07 a 13:44:06 UTC), el Centro de Operaciones de Seguridad (SOC Nivel 2) auditó 715 registros de telemetría SIEM e identificó seis (6) incidentes críticos de ciberseguridad de RIESGO ALTO y una (1) brecha operativa de visibilidad de RIESGO MEDIO. Mientras que las reglas básicas del SIEM solo marcaban 112 alertas, el motor de correlación avanzada vinculó 124 eventos maliciosos al destapar 12 eventos críticos que habían quedado ocultos bajo severidad 'Informational'.

2. IMPACTO CRÍTICO AL NEGOCIO Y EXPOSICIÓN CORPORATIVA

• Sustracción de Información Financiera y Legal Confidencial: Un atacante externo vulneró la cuenta privilegiada CORP\admin en el servidor APP-SRV01, accedió al servidor financiero FS-SRV01 y robó el presupuesto estratégico 'Budget2027.xlsx' (INC-02). Paralelamente, desde el equipo interno WS-018 (usuario CORP\rrojas), se comprimieron y extrajeron 241.57 MiB (253.31 MB / 253,305,558 bytes) de contratos y documentos confidenciales del departamento Legal hacia un servidor externo en 22 transferencias cifradas (INC-04).

• Riesgo Inminente de Parálisis Operativa por Ransomware: La cuenta de servicio de respaldos CORP\backupsvc fue utilizada en la estación WS-023 para recorrer los estados financieros de FY2026 y destruir todas las copias de recuperación locales (Volume Shadow Copies mediante vssadmin.exe), maniobra característica previa al cifrado masivo de archivos (INC-03).

• Compromiso de Activos Públicos y Persistencia en Servidores: El servidor web público WEB-01 fue vulnerado mediante una puerta trasera (Webshell ASPX) que permitió la ejecución remota de comandos (INC-06). Asimismo, en APP-SRV01 se instalaron dos mecanismos ocultos de persistencia (una tarea programada y un servicio de Windows) que ejecutan código no autorizado cada 6 minutos (INC-05), además del compromiso de la cuenta CORP\mgarcia tras un ataque de Password Spraying contra el Controlador de Dominio DC-01 (INC-01).

3. DECISIONES EJECUTIVAS Y PLAN DE ACCIÓN INMEDIATO (0 A 24 HORAS)

• Acción 1 — Autorizar Contención de Red Inmediata: Aislar de forma preventiva los servidores APP-SRV01 y WEB-01, así como las estaciones de trabajo WS-023 (pre-ransomware) y WS-018 (fuga de documentos legales).

• Acción 2 — Activar el Comité de Crisis Legal y Regulatoria: Evaluar el impacto contractual y de protección de datos derivado de la exfiltración de 'Budget2027.xlsx' y de los 241.57 MiB del repositorio Legal, preservando WS-018 bajo cadena de custodia forense.

• Acción 3 — Revocación Masiva de Credenciales y Cierre de Brechas Perimetrales: Forzar el cambio de contraseñas de CORP\admin, CORP\mgarcia, CORP\backupsvc, CORP\rrojas y CORP\helpdesk; eliminar la exposición directa de Escritorio Remoto (RDP) a Internet e implementar Autenticación Multifactor (MFA) obligatoria.

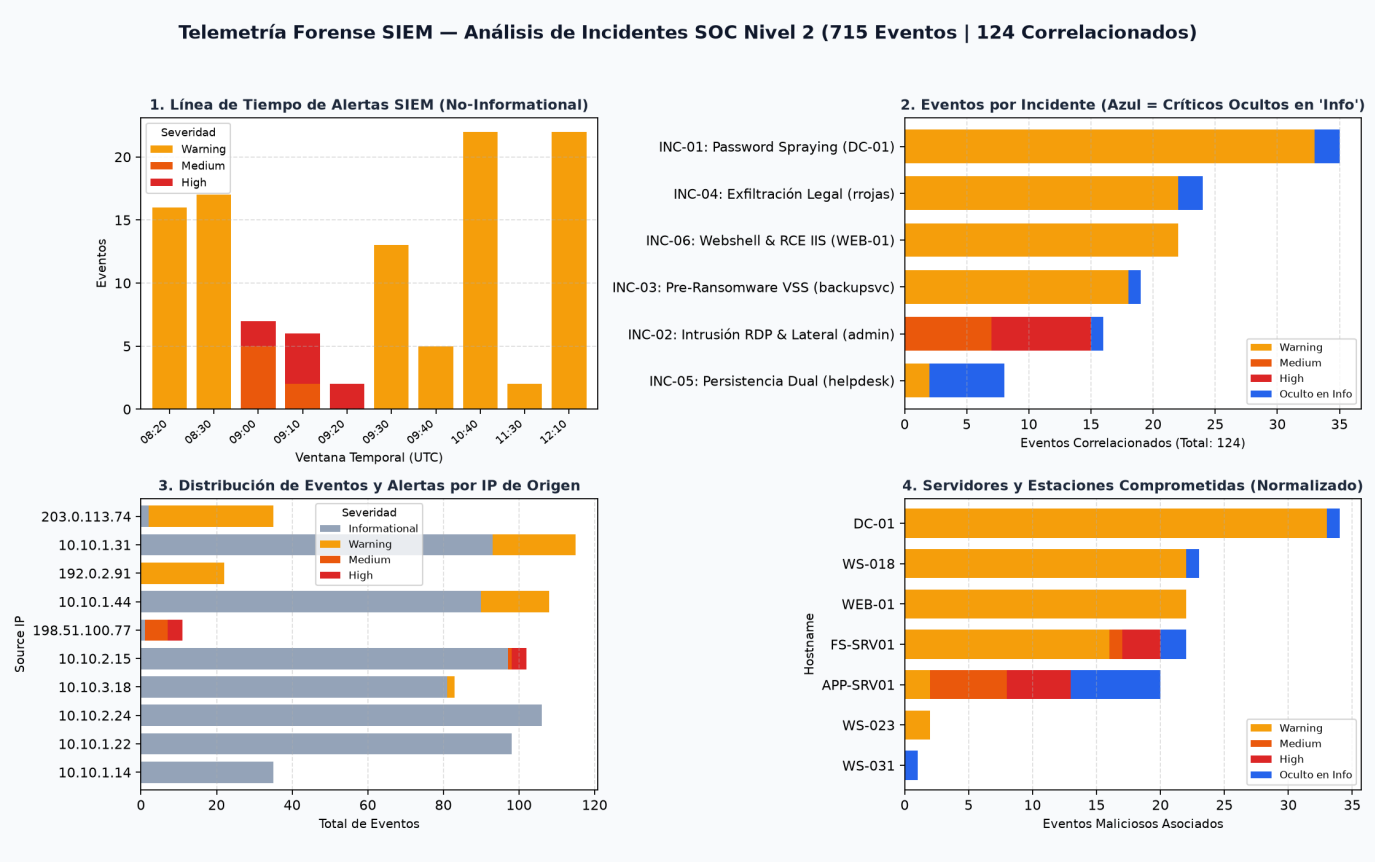
SECCIÓN 2 — MATRIZ EJECUTIVA DE CLASIFICACIÓN DE RIESGO Y MITRE ATT&CK

La siguiente matriz consolida los 6 incidentes críticos de seguridad y la observación de visibilidad SIEM identificados mediante correlación multi-evento sobre los 715 registros del dataset oficial:

ID	Incidente / Hallazgo Detectado	Ventana (UTC)	Activos y Cuentas Involucradas	Técnicas MITRE ATT&CK	Eventos (Info)	Riesgo
INC-01	Password Spraying Externo y Compromiso de Cuenta de Dominio (CORP\mgarcia)	08:25:00 a 08:40:00 (15 min)	DC-01 (Controlador de Dominio), WS-031 (Estación de Trabajo) | 8 cuentas atacadas (jlopez, aperez, helpdesk, mgarcia, rrojas, slopez, backupsvc, dtorres) | Comprometida: CORP\mgarcia	T1110.003 (Password Spraying), T1078.002 (Valid Accounts: Domain Accounts)	35 (2)	**ALTO**
INC-02	Intrusión RDP, Movimiento Lateral SMB y Exfiltración Financiera (Budget2027.xlsx)	09:02:00 a 09:22:00 (20 min)	APP-SRV01 (10.10.2.15), FS-SRV01 (Servidor de Archivos Financieros) | CORP\admin (Cuenta Privilegiada)	T1021.001 (RDP), T1059.001 (PowerShell), T1087.001, T1135 (Share Discovery), T1021.002 (SMB), T1560.001 (Archive via Utility), T1041 (Exfiltration Over C2)	16 (1)	**ALTO**
INC-03	Actividad Pre-Ransomware: Recolección Financiera y Destrucción de Copias de Sombra (VSS)	09:36:00 a 09:43:00 (7 min)	WS-023 (10.10.1.44), FS-SRV01 (\\FS-SRV01\Finance) | CORP\backupsvc (Cuenta de Servicio de Respaldos)	T1059.001 (PowerShell Encoded), T1039 (Data from Network Shared Drive), T1490 (Inhibit System Recovery: vssadmin)	19 (1)	**ALTO**
INC-04	Exfiltración Masiva de Documentación Legal vía HTTPS POST (241.57 MiB / 253.31 MB)	10:40:00 a 10:49:18 (9 min 18 seg)	WS-018 (10.10.1.31), FS-SRV01 (\\FS-SRV01\Legal) | CORP\rrojas	T1039 (Data from Network Shared Drive), T1560.001 (Archive via Utility: 7-Zip), T1048.002 (Exfiltration Over Asymmetric Encrypted Non-C2 Protocol)	24 (2)	**ALTO**
INC-05	Persistencia Dual mediante Tarea Programada y Servicio de Sistema en APP-SRV01	11:35:00 a 12:04:00 (29 min)	APP-SRV01 (Servidor de Aplicaciones) | CORP\helpdesk	T1053.005 (Scheduled Task/Job: Scheduled Task), T1543.003 (Create or Modify System Process: Windows Service)	8 (6)	**ALTO**
INC-06	Explotación de Servidor Web IIS, Webshell ASPX y Ejecución Remota de Comandos (RCE)	12:10:00 a 12:15:00 (5 min)	WEB-01 (Servidor Web Público IIS - Puerto 443) | IIS APPPOOL\DefaultAppPool	T1190 (Exploit Public-Facing Application), T1505.003 (Server Software Component: Web Shell), T1059.003 (Windows Command Shell)	22 (0)	**ALTO**
OBS-01	Brechas de Visibilidad SIEM, Eventos Críticos en 'Informational' y Falta de Normalización	07:46:07 a 13:44:06 (Ventana completa del dataset)	DC-01 (91 logs) vs DC01 (30 logs), WS-022, APP-SRV01, FS-SRV01 | CORP\backupsvc (76 logs) vs CORP\svc_backup (24 logs), CORP\mruiz	T1562 (Impair Defenses / Suboptimal SIEM Severity Rules & Asset Naming)	12 (12)	**MEDIO**

SECCIÓN 3 — VISUALIZACIÓN ANALÍTICA Y DASHBOARD FORENSE DE TELEMETRÍA

El siguiente panel consolida la distribución temporal de alertas, los 124 eventos correlacionados en los 6 incidentes críticos (destacando en azul los 12 eventos críticos que estaban ocultos bajo severidad *Informational*), el volumen por IP de origen y los activos corporativos comprometidos:



AUDITORÍA DE EVASIÓN Y VISIBILIDAD: EVENTOS CRÍTICOS ETIQUETADOS COMO 'INFORMATIONAL'

Un análisis superficial que filtre únicamente *Severity != Informational* omitiría la evidencia de éxito de intrusión y preparación de exfiltración. La correlación SOC Nivel 2 rescató estos 12 registros:

Log_ID	Hora UTC	Incidente	Host	Event_ID	Usuario	IP Origen	Comando / Destino / Relevancia Forense
EVT-00123	08:39:00	**INC-01**	DC-01	4624	CORP\mgarcia	203.0.113.74	Destino: DC-01
EVT-00126	08:40:00	**INC-01**	WS-031	4672	CORP\mgarcia	203.0.113.74	Destino: WS-031
EVT-00237	09:22:00	**INC-02**	APP-SRV01	4634	CORP\admin	198.51.100.77	Destino: -
EVT-00315	09:43:00	**INC-03**	FS-SRV01	5145	CORP\backupsvc	10.10.1.44	Destino: \\FS-SRV01\Finance
EVT-00419	10:40:00	**INC-04**	FS-SRV01	5140	CORP\rrojas	10.10.1.31	Destino: \\FS-SRV01\Legal
EVT-00428	10:42:00	**INC-04**	WS-018	4688	CORP\rrojas	10.10.1.31	7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx
EVT-00519	11:35:00	**INC-05**	APP-SRV01	4624	CORP\helpdesk	10.10.3.18	Destino: -
EVT-00528	11:40:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00542	11:46:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00548	11:52:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00559	11:58:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe
EVT-00564	12:04:00	**INC-05**	APP-SRV01	4688	CORP\helpdesk	10.10.3.18	C:\ProgramData\wuhelper.exe

SECCIÓN 4 — INFORME TÉCNICO DETALLADO (EVIDENCIA FORENSE, IOCs, MITRE ATT&CK Y REMEDIACIÓN)

[INC-01] Password Spraying Externo y Compromiso de Cuenta de Dominio (CORP\mgarcia) — RIESGO ALTO (8.8 (Crítico/Alto))

Ventana de Tiempo: 2026-10-23 08:25:00 a 08:40:00 (15 min) | **Kill Chain:** Initial Access -> Credential Access -> Privilege Escalation
Activos Comprometidos: DC-01 (Controlador de Dominio), WS-031 (Estación de Trabajo) | **Cuentas:** 8 cuentas atacadas (jlopez, aperez, helpdesk, mgarcia, rrojas, slopez, backupsvc, dtorres) | Comprometida: CORP\mgarcia
Mapeo MITRE ATT&CK: T1110.003 (Password Spraying), T1078.002 (Valid Accounts: Domain Accounts)
Indicadores de Compromiso (IoCs): IP Atacante: 203.0.113.74 | Event IDs: 4625 (x33 fallos), 4624 (EVT-00123 login exitoso), 4672 (EVT-00126 privilegios especiales)
Registros de Evidencia (Log_IDs): EVT-00057 a EVT-00111 (33x Event 4625 Warning), EVT-00123 (Event 4624 Informational), EVT-00126 (Event 4672 Informational)
Análisis Forense Detallado: Entre las 08:25:00 y las 08:35:08, la IP pública 203.0.113.74 generó 33 eventos 4625 ('An account failed to log on - bad password') contra DC-01 a un ritmo constante de un intento cada 19 segundos rotando sobre 8 usuarios para evadir umbrales de bloqueo de cuenta. A las 08:39:00 (EVT-00123), el atacante logró un inicio de sesión exitoso (Event ID 4624) con CORP\mgarcia en DC-01, seguido a las 08:40:00 (EVT-00126) por la asignación de privilegios especiales (Event ID 4672) en WS-031. Ambos eventos de éxito estaban etiquetados con severidad 'Informational' en el SIEM.
Plan de Contención y Remediación Paso a Paso:
1. Resetear inmediatamente la contraseña de CORP\mgarcia y revocar todos los tickets Kerberos TGT/TGS activos.
2. Bloquear la IP externa 203.0.113.74 en el Firewall Perimetral.
3. Habilitar MFA obligatorio y configurar políticas de Smart Lockout para autenticaciones externas contra Active Directory.

Playbook CLI / Regla de Contención:
```
Disable-ADAccount -Identity mgarcia; Revoke-AzureADUserAllRefreshToken; New-NetFirewallRule -DisplayName 'Block_IOC_203.0.113.74' -Direction Inbound -RemoteAddress 203.0.113.74 -Action Block
```

[INC-02] Intrusión RDP, Movimiento Lateral SMB y Exfiltración Financiera (Budget2027.xlsx) — RIESGO ALTO (9.6 (Crítico))

Ventana de Tiempo: 2026-10-23 09:02:00 a 09:22:00 (20 min) | **Kill Chain:** Initial Access -> Execution -> Discovery -> Lateral Movement -> Collection -> Exfiltration
Activos Comprometidos: APP-SRV01 (10.10.2.15), FS-SRV01 (Servidor de Archivos Financieros) | **Cuentas:** CORP\admin (Cuenta Privilegiada)
Mapeo MITRE ATT&CK: T1021.001 (RDP), T1059.001 (PowerShell), T1087.001, T1135 (Share Discovery), T1021.002 (SMB), T1560.001 (Archive via Utility), T1041 (Exfiltration Over C2)
Indicadores de Compromiso (IoCs): IPs Externas: 198.51.100.77 (RDP Ingress), 203.0.113.88:443 (Exfil C2) | IP Interna Pivote: 10.10.2.15 | Archivos: Finance\Budget2027.xlsx, C:\Temp\finance.zip
Registros de Evidencia (Log_IDs): EVT-00174..00180 (4x 4625 RDP), EVT-00188 (4624 RDP), EVT-00193 (4672), EVT-00198 (PS Encoded), EVT-00207 (4104 ScriptBlock), EVT-00214 (net view), EVT-00222..00231 (SMB/Budget2027.xlsx), EVT-00232 (tar.exe), EVT-00235 (5156 Exfil), EVT-00237 (4634 Info)
Análisis Forense Detallado: La IP externa 198.51.100.77 realizó 4 intentos fallidos por RDP (LogonType=10, Event ID 4625) entre las 09:02 y 09:05 contra CORP\admin en APP-SRV01, logrando acceso exitoso a las 09:06:00 (EVT-00188) y privilegios especiales (EVT-00193). A las 09:09:00 ejecutó 'powershell.exe -NoProfile -EncodedCommand [REDACTED_SYNTHETIC]' (EVT-00198) e invocó el bloque de script 'Get-LocalGroupMember Administrators; Get-SmbShare' (Event ID 4104, EVT-00207) y 'net.exe view \\FS-SRV01' (EVT-00214). A las 09:16:00 saltó por red (LogonType=3, EVT-00225) desde APP-SRV01 (10.10.2.15) hacia FS-SRV01, accedió a '\\FS-SRV01\Finance\Budget2027.xlsx' (Event ID 5145, EVT-00231), creó el paquete de staging 'tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports' (EVT-00232), exfiltró el archivo hacia 203.0.113.88:443 usando powershell.exe (Event ID 5156, EVT-00235) y cerró sesión a las 09:22:00 (EVT-00237, Informational).
Plan de Contención y Remediación Paso a Paso:
1. Aislar inmediatamente APP-SRV01 de la red corporativa y cerrar toda exposición directa de RDP (TCP/3389) hacia Internet.
2. Rotar las credenciales de CORP\admin y auditar todas las sesiones SMB originadas desde 10.10.2.15.
3. Bloquear las IPs 198.51.100.77 y 203.0.113.88 en el Firewall Perimetral y eliminar C:\Temp\finance.zip tras su preservación forense.

Playbook CLI / Regla de Contención:
```
Disable-NetAdapter -Name 'Ethernet0' -Confirm:$false; Stop-Service TermService -Force; Remove-Item -Path 'C:\Temp\finance.zip' -Force
```

[INC-03] Actividad Pre-Ransomware: Recolección Financiera y Destrucción de Copias de Sombra (VSS) — RIESGO ALTO (9.4 (Crítico))

Ventana de Tiempo: 2026-10-23 09:36:00 a 09:43:00 (7 min) | **Kill Chain:** Execution -> Collection -> Impact (Inhibit System Recovery)
Activos Comprometidos: WS-023 (10.10.1.44), FS-SRV01 (\\FS-SRV01\Finance) | **Cuentas:** CORP\backupsvc (Cuenta de Servicio de Respaldos)
Mapeo MITRE ATT&CK: T1059.001 (PowerShell Encoded), T1039 (Data from Network Shared Drive), T1490 (Inhibit System Recovery: vssadmin)
Indicadores de Compromiso (IoCs): IP Interna: 10.10.1.44 (WS-023) | Comandos: powershell.exe -NoProfile -EncodedCommand <base64_redacted> (EVT-00280), vssadmin.exe delete shadows /all /quiet (EVT-00314)
Registros de Evidencia (Log_IDs): EVT-00280 (Event 4688 PS Base64), EVT-00284 a EVT-00309 (16x Event 4663 sobre Finance\FY2026\document_000..015.xlsx), EVT-00314 (Event 4688 vssadmin), EVT-00315 (Event 5145 Info)
Análisis Forense Detallado: A las 09:36:00 en el host WS-023 (10.10.1.44), la cuenta CORP\backupsvc ejecutó 'powershell.exe -NoProfile -EncodedCommand <base64_redacted>' (Event ID 4688, EVT-00280). Entre las 09:37:00 y las 09:41:00 (EVT-00284 a EVT-00309) realizó un barrido secuencial automatizado cada 16 segundos sobre 16 archivos en '\\FS-SRV01\Finance' (Finance\FY2026\document_000.xlsx hasta document_015.xlsx, Event ID 4663). Finalmente, a las 09:42:00 (EVT-00314), ejecutó 'vssadmin.exe delete shadows /all /quiet' en WS-023 para destruir las copias de sombra del volumen e impedir la recuperación, seguido a las 09:43:00 (EVT-00315, Informational) por una verificación de permisos sobre '\\FS-SRV01\Finance' (Event ID 5145).
Plan de Contención y Remediación Paso a Paso:
1. Aislar de inmediato la estación WS-023 (10.10.1.44) de la red para frenar cualquier proceso de cifrado sobre recursos SMB.
2. Deshabilitar temporalmente la cuenta de servicio CORP\backupsvc y restringir sus permisos mediante Group Managed Service Accounts (gMSA).
3. Verificar la integridad de los respaldos inmutables/offline de FS-SRV01 y bloquear vssadmin.exe mediante reglas Attack Surface Reduction (ASR).

```
Playbook CLI / Regla de Contención:
Disable-ADAccount -Identity backupsvc; Stop-Computer -ComputerName WS-023 -Force; Add-MpPreference
-AttackSurfaceReductionRules_Ids 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 -AttackSurfaceReductionRules_Actions Enabled
```

[INC-04] Exfiltración Masiva de Documentación Legal vía HTTPS POST (241.57 MiB / 253.31 MB) — RIESGO ALTO (8.9 (Alto))

Ventana de Tiempo: 2026-10-23 10:40:00 a 10:49:18 (9 min 18 seg) | **Kill Chain:** Collection -> Staging -> Exfiltration
Activos Comprometidos: WS-018 (10.10.1.31), FS-SRV01 (\\FS-SRV01\Legal) | **Cuentas:** CORP\rrojas
Mapeo MITRE ATT&CK: T1039 (Data from Network Shared Drive), T1560.001 (Archive via Utility: 7-Zip), T1048.002 (Exfiltration Over Asymmetric Encrypted Non-C2 Protocol)
Indicadores de Compromiso (IoCs): IP Externa Destino: 198.51.100.88:443 (/upload/session/1..22) | Archivo: C:\Users\Public\archive.7z | Total Exfiltrado: 253,305,558 bytes (241.57 MiB)
Registros de Evidencia (Log_IDs): EVT-00419 (Event 5140 Info: \\FS-SRV01\Legal), EVT-00428 (Event 4688 Info: 7z.exe), EVT-00430 a EVT-00461 (22x PROXY_ACCESS HTTPS POST)
Análisis Forense Detallado: A las 10:40:00 (EVT-00419, severidad 'Informational'), el usuario CORP\rrojas desde WS-018 (10.10.1.31) accedió al recurso compartido '\\FS-SRV01\Legal' (Event ID 5140). Dos minutos después, a las 10:42:00 (EVT-00428, también marcado como 'Informational'), ejecutó el comando '7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx' (Event ID 4688). Inmediatamente, entre las 10:43:00 y las 10:49:18 (EVT-00430 a EVT-00461), realizó 22 peticiones HTTPS POST consecutivas cada 18 segundos a través del Proxy hacia 198.51.100.88:443 (URIs /upload/session/1 hasta /upload/session/22), exfiltrando exactamente 253,305,558 bytes (241.57 MiB / 253.31 MB).
Plan de Contención y Remediación Paso a Paso:
1. Bloquear de inmediato el destino 198.51.100.88 en el Proxy Corporativo y Firewall Perimetral.
2. Asegurar la estación WS-018 bajo cadena de custodia forense (preservar C:\Users\Public\archive.7z y artefactos de memoria/disco).
3. Notificar al Comité Legal y de Cumplimiento/Privacidad para evaluar el alcance de los documentos *.docx comprometidos.

```
Playbook CLI / Regla de Contención:
Suspend-ADAccount -Identity rrojas; Get-FileHash 'C:\Users\Public\archive.7z' -Algorithm SHA256;
New-NetFirewallRule -DisplayName 'Block_Exfil_198.51.100.88' -Direction Outbound -RemoteAddress 198.51.100.88
-Action Block
```

[INC-05] Persistencia Dual mediante Tarea Programada y Servicio de Sistema en APP-SRV01 — RIESGO ALTO (8.6 (Alto))

Ventana de Tiempo: 2026-10-23 11:35:00 a 12:04:00 (29 min) | **Kill Chain:** Initial Logon -> Persistence -> Privilege Escalation -> Execution
Activos Comprometidos: APP-SRV01 (Servidor de Aplicaciones) | **Cuentas:** CORP\helpdesk
Mapeo MITRE ATT&CK: T1053.005 (Scheduled Task/Job: Scheduled Task), T1543.003 (Create or Modify System Process: Windows Service)
Indicadores de Compromiso (IoCs): Origen: 10.10.3.18 | Tarea: \Microsoft\Windows\UpdateCheck (C:\ProgramData\updatecheck.ps1) | Servicio: WinUpdateHelper (C:\ProgramData\wuhelper.exe)
Registros de Evidencia (Log_IDs): EVT-00519 (Event 4624 Info), EVT-00523 (Event 4698 Task Created), EVT-00524 (Event 7045 Service Installed), EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564 (5x Event 4688 Info wuhelper.exe)
Análisis Forense Detallado: A las 11:35:00 (EVT-00519, Informational), la cuenta CORP\helpdesk inició sesión en APP-SRV01 desde 10.10.3.18. A las 11:37:00 (EVT-00523, Event ID 4698) creó la tarea programada '\Microsoft\Windows\UpdateCheck' configurada para ejecutar 'powershell.exe -File C:\ProgramData\updatecheck.ps1'. Un minuto después, a las 11:38:00 (EVT-00524, Event ID 7045), instaló el servicio de sistema 'WinUpdateHelper' apuntando al binario 'C:\ProgramData\wuhelper.exe'. Posteriormente, dicho binario se ejecutó periódicamente cada 6 minutos a las 11:40, 11:46, 11:52, 11:58 y 12:04 (EVT-00528, EVT-00542, EVT-00548, EVT-00559 y EVT-00564, 5 eventos Event ID 4688 etiquetados como 'Informational').
Plan de Contención y Remediación Paso a Paso:
1. Detener y eliminar el servicio 'WinUpdateHelper' y anular el registro de la tarea programada '\Microsoft\Windows\UpdateCheck' en APP-SRV01.
2. Extraer copias forenses (hashing SHA-256 y análisis estático/dinámico) de C:\ProgramData\wuhelper.exe y C:\ProgramData\updatecheck.ps1 antes de su borrado.
3. Auditar la estación 10.10.3.18 y revocar privilegios administrativos de CORP\helpdesk sobre servidores de producción.

Playbook CLI / Regla de Contención:
```
Stop-Service -Name 'WinUpdateHelper' -Force; sc.exe delete WinUpdateHelper; Unregister-ScheduledTask -TaskName 'UpdateCheck' -TaskPath '\Microsoft\Windows\' -Confirm:$false
```

[INC-06] Explotación de Servidor Web IIS, Webshell ASPX y Ejecución Remota de Comandos (RCE) — RIESGO ALTO (9.8 (Crítico))

Ventana de Tiempo: 2026-10-23 12:10:00 a 12:15:00 (5 min) | **Kill Chain:** Reconnaissance -> Exploitation -> Persistence (Webshell) -> Execution (RCE)
Activos Comprometidos: WEB-01 (Servidor Web Público IIS - Puerto 443) | **Cuentas:** IIS APPPOOL\DefaultAppPool
Mapeo MITRE ATT&CK: T1190 (Exploit Public-Facing Application), T1505.003 (Server Software Component: Web Shell), T1059.003 (Windows Command Shell)
Indicadores de Compromiso (IoCs): IP Atacante: 192.0.2.91 | Webshell URI: /uploads/test.aspx?cmd=whoami | Endpoints sondeados: /admin/, /login?user=admin, /api/v1/export | Proceso hijo: cmd.exe /c whoami
Registros de Evidencia (Log_IDs): EVT-00571 a EVT-00596 (21x HTTP_ACCESS Warning desde 192.0.2.91: 6x HTTP 200, 6x HTTP 404, 9x HTTP 500), EVT-00599 (Event 4688 cmd.exe /c whoami)
Análisis Forense Detallado: Entre las 12:10:00 y las 12:14:00 (EVT-00571 a EVT-00596), la IP externa 192.0.2.91 envió 21 peticiones HTTP/HTTPS contra WEB-01:443 enumerando '/login?user=admin', '/admin/' y '/api/v1/export' (provocando 9 errores HTTP 500, 6 HTTP 404 y 6 HTTP 200), e invocando la webshell '/uploads/test.aspx?cmd=whoami' (código HTTP 200 en EVT-00571). A las 12:15:00 (EVT-00599, Event ID 4688), el proceso de aplicación de IIS bajo la identidad 'IIS APPPOOL\DefaultAppPool' instanció un shell del sistema ejecutando 'cmd.exe /c whoami', confirmando Ejecución Remota de Código (RCE).
Plan de Contención y Remediación Paso a Paso:
1. Poner WEB-01 en modo mantenimiento o aislarlo en la DMZ, eliminar '/uploads/test.aspx' y auditar todo el directorio web en busca de otras webshells.
2. Configurar IIS para deshabilitar permisos de ejecución de scripts (Handler Mappings ASPX/PHP) en el directorio '/uploads/'.
3. Bloquear la IP 192.0.2.91 en el WAF/Firewall y aplicar reglas de endurecimiento para impedir que w3wp.exe ejecute cmd.exe o powershell.exe.

Playbook CLI / Regla de Contención:
```
Remove-Item -Path 'C:\inetpub\wwwroot\uploads\test.aspx' -Force; Stop-WebAppPool -Name 'DefaultAppPool'; New-NetFirewallRule -DisplayName 'Block_WebAttacker_192.0.2.91' -Direction Inbound -RemoteAddress 192.0.2.91 -Action Block
```

[OBS-01] Brechas de Visibilidad SIEM, Eventos Críticos en 'Informational' y Falta de Normalización — RIESGO MEDIO (6.5 (Medio - Riesgo Operativo SOC))

Ventana de Tiempo: 2026-10-23 07:46:07 a 13:44:06 (Ventana completa del dataset) | **Kill Chain:** Defense Evasion -> SIEM Telemetry Blindspots -> Asset Fragmentation
Activos Comprometidos: DC-01 (91 logs) vs DC01 (30 logs), WS-022, APP-SRV01, FS-SRV01 | **Cuentas:** CORP\backupsvc (76 logs) vs CORP\svc_backup (24 logs), CORP\mruiz
Mapeo MITRE ATT&CK: T1562 (Impair Defenses / Suboptimal SIEM Severity Rules & Asset Naming)
Indicadores de Compromiso (IoCs): 12 eventos críticos de intrusión etiquetados como Informational; inconsistencia de nombres en agentes SIEM
Registros de Evidencia (Log_IDs): EVT-00123 (4624), EVT-00126 (4672), EVT-00237 (4634), EVT-00315 (5145), EVT-00419 (5140), EVT-00428 (4688 7z.exe), EVT-00519 (4624), EVT-00528, EVT-00542, EVT-00548, EVT-00559, EVT-00564 (5x 4688 wuhelper.exe)
Análisis Forense Detallado: Un filtro básico de Nivel 1 que descarte 'Severity == Informational' perdería 12 eventos clave de la cadena de ataque (diferencia entre las 112 alertas nativas del SIEM y los 124 eventos maliciosos correlacionados): el login exitoso tras Password Spraying (EVT-00123) y su escalamiento (EVT-00126), el cierre de sesión RDP de CORP\admin (EVT-00237), la verificación de permisos SMB post-vssadmin (EVT-00315), el acceso al recurso Legal (EVT-00419) y su empaquetado con 7z.exe (EVT-00428), el login de CORP\helpdesk (EVT-00519) y las 5 ejecuciones del binario persistente C:\ProgramData\wuhelper.exe (EVT-00528, EVT-00542, EVT-00548, EVT-00559 y EVT-00564). Asimismo, el Controlador de Dominio reporta como 'DC-01' (91 eventos) y 'DC01' (30 eventos), y coexisten las cuentas 'CORP\backupsvc' (76) y 'CORP\svc_backup' (24).
Plan de Contención y Remediación Paso a Paso:
1. Implementar reglas de correlación Sigma en el SIEM para alertar sobre Event ID 4624/4672 precedidos por ráfagas de Event ID 4625 desde la misma IP.
2. Elevar a severidad 'High' toda creación de procesos (Event ID 4688) originada en rutas públicas (C:\ProgramData\, C:\Users\Public\, C:\Temp\) o utilidades de archivado (7z.exe, tar.exe).
3. Estandarizar los agentes colectores de logs para unificar el hostname 'DC01' -> 'DC-01' y auditar la nomenclatura de cuentas de servicio.

```
Playbook CLI / Regla de Contención:
# Regla Sigma / KQL recomendada: SecurityEvent | where EventID == 4688 and (CommandLine has_any
('C:\\ProgramData\\', 'C:\\Users\\Public\\', '7z.exe', 'tar.exe', 'vssadmin'))
```

SECCIÓN 5 — INGENIERÍA DE DETECCIÓN: LOLBAS, GTFOBINS Y REGLAS SIGMA, YARA & YARA-X

Para erradicar la evasión basada en binarios nativos (*Living Off The Land*) y corregir los 12 falsos negativos registrados bajo severidad *Informational* (OBS-01), se documenta la matriz de correlación contra **LOLBAS** (https://lolbas-project.github.io/) y **GTFOBins** (https://gtfobins.org/), seguida de las reglas de detección para SIEM (**Sigma**) y EDR/DFIR (**YARA Clásico** y **YARA-X en Rust**):

Binario / Utilidad	Catálogo	Incidente (Log_IDs)	Comando Detectado en Telemetría SIEM	MITRE ATT&CK / Referencia Oficial
vssadmin.exe	LOLBAS	INC-03 (EVT-00314)	vssadmin.exe delete shadows /all /quiet	T1490 (Inhibit System Recovery) | https://lolbas-project.github.io/lolbas/Binaries/Vssadmin/ | https://gtfobins.org/
tar.exe (bsdtar)	LOLBAS + GTFOBins	INC-02 (EVT-00232)	tar.exe -a -c -f C:\Temp\finance.zip C:\Temp\reports	T1560.001 (Archive via Utility) | https://lolbas-project.github.io/lolbas/Binaries/Tar/ | https://gtfobins.org/gtfobins/tar/
7z.exe / 7z	GTFOBins + Utility Abuse	INC-04 (EVT-00428 (Oculto en Informational))	7z.exe a C:\Users\Public\archive.7z C:\Legal*.docx	T1560.001 (Archive via Utility) | https://lolbas-project.github.io/ | https://gtfobins.org/gtfobins/7z/
powershell.exe	LOLBAS	INC-02, INC-03 (EVT-00198, EVT-00207, EVT-00235, EVT-00280)	powershell.exe -NoProfile -EncodedCommand <base64_redacted>	T1059.001 (PowerShell), T1027 (Obfuscated Files) | https://lolbas-project.github.io/lolbas/Binaries/Powershell/ | https://gtfobins.org/
schtasks.exe	LOLBAS	INC-05 (EVT-00523)	Tarea programada \Microsoft\Windows\UpdateCheck -> C:\ProgramData\wuhelper.exe	T1053.005 (Scheduled Task/Job: Scheduled Task) | https://lolbas-project.github.io/lolbas/Binaries/Schtasks/ | https://gtfobins.org/gtfobins/crontab/
sc.exe (Service Control)	LOLBAS	INC-05 (EVT-00524, EVT-00528..00564 (5x Info))	Servicio WinUpdateHelper -> C:\ProgramData\wuhelper.exe	T1543.003 (Create or Modify System Process: Windows Service) | https://lolbas-project.github.io/lolbas/Binaries/Sc/ | https://gtfobins.org/gtfobins/systemctl/

Binario / Utilidad	Catálogo	Incidente (Log_IDs)	Comando Detectado en Telemetría SIEM	MITRE ATT&CK / Referencia Oficial
net.exe	LOLBAS	INC-02 (EVT-00214)	net.exe view \\FS-SRV01	T1135 (Network Share Discovery) | https://lolbas-project.github.io/lolbas/Binaries/Net/ | https://gtfobins.org/
cmd.exe / whoami.exe	LOLBAS + GTFOBins	INC-06 (EVT-00571, EVT-00599)	cmd.exe /c whoami (invocado desde /uploads/test.aspx?cmd=whoami)	T1505.003 (Web Shell), T1059.003 (Windows Command Shell) | https://lolbas-project.github.io/lolbas/Binaries/Cmd/ | https://gtfobins.org/gtfobins/sh/

ANEXO DE REGLAS DE PRODUCCIÓN — SIGMA (.YML) & YARA-X NEXT-GEN RUST (.YARX)

Regla Sigma SIEM (.yml) — LOLBAS & Informational

```
title: SOC L2 - Abuso de LOLBAS para Staging, Ransomware VSS y
Persistencia
id: 8f4b2c10-9d3a-4e7b-b122-6c9a0e54f201
status: production
description: >
Detecta la ejecución de binarios LOLBAS/GTFOBins observados en
los incidentes INC-02,
INC-03, INC-04, INC-05 e INC-06, incluyendo aquellos
etiquetados erróneamente como
Informational por el SIEM (EVT-00428 7z.exe y EVT-00528..00564
wuhelper.exe).
author: JEV Cyber Command OS (SOC Nivel 2)
date: 2026/10/23
references:
- https://lolbas-project.github.io/lolbas/Binaries/Vssadmin/
- https://lolbas-project.github.io/lolbas/Binaries/Tar/
- https://gtfobins.org/gtfobins/7z/
logsource:
category: process_creation
product: windows
detection:
selection_vss_ransomware:
EventID: 4688
CommandLine|contains|all:
- 'vssadmin'
- 'delete'
- 'shadows'
selection_lolbas_archivers:
EventID: 4688
CommandLine|contains:
- 'tar.exe -a -c -f C:\Temp\finance.zip'
- '7z.exe a C:\Users\Public\archive.7z'
- 'C:\Users\Public\'
- 'C:\Temp\'
selection_encoded_powershell:
EventID: 4688
CommandLine|contains:
- '-EncodedCommand'
- '-enc '
selection_rogue_service_binary:
EventID: 4688
CommandLine|contains: 'C:\ProgramData\wuhelper.exe'
selection_iis_webshell_rce:
EventID: 4688
User|contains: 'DefaultAppPool'
CommandLine|contains: 'cmd.exe /c whoami'
condition: 1 of selection_*
falsepositives:
- Tareas administrativas legítimas debidamente firmadas y fuera
de rutas públicas
level: critical
tags:
- attack.impact
- attack.t1490
- attack.collection
- attack.t1560.001
- attack.persistence
- attack.t1543.003
- attack.t1505.003
```

Regla YARA-X Rust (.yarx — VirusTotal Engine)

```
REGLAS YARA-X (.yarx) — MOTOR NEXT-GEN EN RUST (VIRUSTOTAL)
Sintaxis estricta compatible con `yr scan` (YARA-X CLI / Rust
Engine)
import "pe"
rule YARAX_SOC_L2_MultiIncident_Artifact_Detector
{
meta:
engine = "YARA-X (VirusTotal Rust Engine >= 0.10)"
author = "JEV Cyber Command OS - SOC Nivel 2"
incidents_covered = "INC-02, INC-03, INC-04, INC-05, INC-06"
lolbas_catalog = "https://lolbas-project.github.io/"
gtfobins_catalog = "https://gtfobins.org/"
tlp = "AMBER+STRICT"
strings:
$persist_bin = "C:\ProgramData\wuhelper.exe" ascii wide nocase
$persist_svc = "WinUpdateHelper" ascii wide
$persist_task = "\Microsoft\Windows\UpdateCheck" ascii wide
$lolbas_vss =
/vssadmin(\.exe)?\s+delete\s+shadows\s+\/all\s+\/quiet/i
$stage_finance = "C:\Temp\finance.zip" ascii wide nocase
$stage_legal = "C:\Users\Public\archive.7z" ascii wide nocase
$target_budget = "Budget2027.xlsx" ascii wide nocase
$webshell_uri = "/uploads/test.aspx" ascii wide nocase
$webshell_cmd = "cmd.exe /c whoami" ascii wide nocase
$c2_legal_ip = "198.51.100.88:443" ascii wide
$c2_fin_ip = "203.0.113.88:443" ascii wide
condition:
(
pe.is_pe and
(
$persist_bin or
($persist_svc and $persist_task)
)
)
or any of ($lolbas_vss, $stage_finance, $stage_legal,
$target_budget)
or ($webshell_uri and $webshell_cmd)
or any of ($c2_legal_ip, $c2_fin_ip)
}
```